

Report Progetto: Cyber Security & Ethical Hacking

Autore:	Leandro Ancona
Ambito:	Cybersecurity, Ethical Hacking & Systems Administration
Data Redazione:	Giugno 2026

Indice

1. Considerazioni Iniziali
2. Esercizio 1: Amministrazione di Sistema e Automazione tramite Windows PowerShell
3. Esercizio 2: Studio degli IoC (Indicator of Compromise) in Sandbox
4. Bonus 1: Attività di Network Scanning ed Esplorazione delle Funzionalità di Nmap
5. Bonus 2: Analisi Forense di un Attacco SQL Injection su Database MySQL tramite Wireshark
6. Conclusioni Finali

1. Considerazioni Iniziali

Il presente report documenta in modo dettagliato le attività pratiche e di analisi svolte in ambiente di laboratorio isolato, mirate all'approfondimento dell'amministrazione di sistema (mediante l'uso della CLI Windows PowerShell) e alla valutazione della sicurezza delle infrastrutture di rete e delle applicazioni web (tramite Nmap e Wireshark).

L'obiettivo didattico primario consiste nel comprendere come l'automazione dei processi, le tecniche di ricognizione attiva e l'analisi forense dei pacchetti di rete costituiscano competenze fondamentali e complementari per un professionista della sicurezza. Lo studio approfondito copre sia gli aspetti difensivi di gestione sistemistica, sia le metodologie di attacco reali, come le vulnerabilità di tipo SQL Injection, identificandone i vettori di sfruttamento e strutturando

contromisure di mitigazione efficaci.

2. Esercizio 1: Amministrazione di Sistema e Automazione tramite Windows PowerShell

PowerShell è una shell a riga di comando e un linguaggio di scripting basato su object-oriented framework, sviluppato da Microsoft per l'automazione delle attività di configurazione e gestione dei sistemi operativi. A differenza delle shell testuali tradizionali, PowerShell scambia dati sotto forma di oggetti .NET complessi, permettendo una granularità e un controllo avanzato sui flussi di lavoro.

Parte 2: Esplorazione comparativa tra il Prompt dei Comandi (CMD) e PowerShell

Confronto sull'output del comando dir:

- **Prompt dei Comandi (CMD):** L'esecuzione produce un output puramente testuale, formattato in colonne statiche che includono data, ora di creazione, l'eventuale tag di directory <DIR> o la dimensione del singolo file, seguita dal nome del file/cartella.
- **Windows PowerShell:** L'output è in realtà una rappresentazione visiva di un array di oggetti di tipo System.IO.DirectoryInfo e System.IO.FileInfo. La tabella risultante visualizza in modo nativo attributi di sicurezza e di stato avanzati, tra cui:
 - Mode: Indica i permessi strutturati (es. d---- per le directory, -a--- per i file pronti per l'archiviazione).
 - LastWriteTime: Timestamp preciso dell'ultima modifica effettuata.
 - Length: Dimensione dell'elemento espressa rigidamente in byte.
 - Name: Nome dell'oggetto di riferimento (es. WWAHost.exe).

Analisi della configurazione di rete tramite ipconfig:

L'interrogazione della configurazione delle interfacce di rete attive sul sistema ha rilevato i seguenti parametri statici associati alla scheda Ethernet locale:

Parametro di Rete	Valore Rilevato
Indirizzo IPv4 dell'Host	192.168.20.100

Parametro di Rete	Valore Rilevato
Subnet Mask (Maschera di Sottorete)	255.255.255.0 (/24)
Gateway Predefinito (Default Gateway)	192.168.20.1

Parte 3: Meccanismi di Alias e Cmdlet nativi

In PowerShell, molti comandi tradizionali del CMD o di sistemi Unix-like sono mappati tramite alias per agevolare la transizione degli amministratori di sistema. Interrogando l'ambiente tramite il comando `Get-Alias dir`, viene evidenziato come l'istruzione `dir` non sia un file eseguibile separato, ma un semplice puntatore sintattico (Alias) che reindirizza la chiamata verso il cmdlet nativo ed effettivo denominato `Get-ChildItem`.

Parte 4: Monitoraggio delle Connessioni e Correlazione Processi con netstat

La CLI di diagnostica `netstat` (Network Statistics) permette di monitorare lo stato dello stack di rete locale:

- **Consultazione della Guida:** Tramite il comando `netstat -h` vengono esaminate le opzioni di esecuzione, tra cui spiccano l'argomento `-a` (per mostrare tutte le connessioni attive e le porte TCP/UDP in ascolto) e l'opzione `-b` (fondamentale per visualizzare l'eseguibile binario coinvolto nella creazione della connessione).
- **Determinazione della Tabella di Routing:** Eseguendo il comando `netstat -r`, viene esposta la tabella di instradamento del kernel IP. Per la rotta di default identificata dalla destinazione di rete 0.0.0.0 (quad-zero route, usata per inoltrare tutto il traffico non diretto alla sottorete locale verso la rete pubblica Internet), il sistema convalida l'utilizzo del gateway d'uscita attestato sull'IP 192.168.20.1.
- **Correlazione Avanzata PID-Processo:** Avviando la shell con privilegi amministrativi elevati ed eseguendo il comando mirato:

```
netstat -abno
```

Vengono mappate in tempo reale tutte le porte in stato di *LISTENING* (ascolto) o *ESTABLISHED* (connessione instaurata), esplicitando l'identificativo numerico del processo chiamante denominato **PID (Process ID)**.
Incrociando questo valore numerico all'interno della scheda **"Dettagli"** o della finestra delle **"Proprietà"** in Gestione Attività (Task Manager), un SOC Analyst o un amministratore può raccogliere indicatori critici relativi alla sicurezza dell'host: il percorso esatto del binario sul

disco (es. lsass.exe o le istanze specifiche di svchost.exe), lo stato operativo corrente, il contesto utente sotto cui il processo è agganciato (es. gli account a massimi privilegi SYSTEM, NETWORK SERVICE o LOCAL SERVICE), la quantità di memoria RAM allocata e la descrizione del servizio Windows ad esso associato.

Parte 5: Automazione delle procedure di manutenzione

L'automazione sistemistica permette l'epurazione pianificata delle risorse obsolete. Invocando il cmdlet nativo Clear-RecycleBin, la shell avvia una routine di protezione che richiede una conferma esplicita all'operatore tramite un prompt interattivo (*"Are you sure you want to perform this action?"*). Fornendo in input il flag affermativo [Y], PowerShell comunica direttamente con le API del file system, eseguendo la cancellazione definitiva e irreversibile di tutti i file memorizzati nel Cestino di sistema senza necessità di interagire con l'interfaccia grafica (GUI).

3. Esercizio 2: Studio degli IoC (Indicator of Compromise) in Ambiente Sandbox

L'analisi dinamica del malware e delle minacce persistenti avanzate viene condotta all'interno di piattaforme di **Sandbox interattive cloud-based** (quali *Any.Run* o ambienti dedicati). Questa metodologia permette di detonare artefatti sospetti, eseguibili malevoli o link ipertestuali potenzialmente infetti all'interno di un sistema operativo guest Windows o Linux completamente isolato dal resto della rete aziendale.

L'obiettivo primario di questo studio è l'estrazione e la catalogazione degli **IoC (Indicators of Compromise)**, ovvero le tracce digitali lasciate da un'infezione informatica. Attraverso l'osservazione in tempo reale del comportamento della minaccia, l'analista è in grado di tracciare la catena d'attacco secondo i framework standard del settore (come il MITRE ATT&CK):

- **Connessioni Network di C2 (Command & Control):** Identificazione di chiamate DNS verso domini malevoli di recente registrazione e tentativi di connessione remota verso indirizzi IP associati a server di comando dai quali il malware riceve istruzioni o scarica payload secondari.
- **Tecniche di Persistenza e Manipolazione del Sistema:** Monitoraggio di modifiche non autorizzate al Registro di Sistema di Windows (es. alterazioni delle chiavi di *Run/RunOnce*), creazione di servizi di sistema persistenti nascosti o iniezioni di codice all'interno di processi legittimi.

- **Attività di Esfiltrazione Dati:** Tracciamento dei tentativi di lettura e compressione di file sensibili archiviati sui profili utente, pronti per essere inviati all'esterno dell'infrastruttura.

La corretta estrazione di questi indicatori (come hash crittografici SHA-256 dei file, IP di C2 e pattern di stringhe) è un prerequisito fondamentale per la sicurezza difensiva: essi permettono la tempestiva generazione di regole di blocco perimetrali sui firewall aziendali, l'aggiornamento delle firme sui sistemi di rilevamento intrusioni (IDS/IPS) e la configurazione di policy di rilevamento automatico sugli agenti EDR/SIEM.

4. Bonus 1: Attività di Network Scanning ed Esplorazione delle Funzionalità di Nmap

Nmap (Network Mapper) è lo strumento open source di riferimento per l'attività di *reconnaissance* (ricognizione) attiva, l'auditing dei sistemi di sicurezza e la mappatura delle superfici di attacco di una rete.

Parte 1: Logica di Esecuzione dei Comandi di Scansione

Prendendo come riferimento lo standard operativo per la scansione avanzata di un host remoto, viene analizzata la seguente sintassi d'esempio:

```
# nmap -A -T4 scanme.nmap.org
```

La scomposizione tecnica dei flag di input evidenzia le seguenti funzionalità di Nmap:

- **-A (Aggressive Scan):** Attiva in un'unica istruzione un set combinato di scansioni ad alto valore informativo, includendo l'**OS Detection** (rilevamento del sistema operativo target tramite fingerprinting dello stack TCP/IP), la **Version Detection** (identificazione dei banner e della versione esatta dei software in ascolto sulle porte), il caricamento dei core script del motore **NSE (Nmap Scripting Engine)** per identificare vulnerabilità note, e l'esecuzione del **traceroute**.
- **-T4 (Timing Template):** Seleziona una policy di temporizzazione di tipo *Aggressive*. Ottimizza i tempi di attesa per i pacchetti di risposta, velocizzando drasticamente l'esecuzione del tool. È l'impostazione ideale per reti locali stabili e moderne, riducendo i delay senza compromettere l'accuratezza del risultato.
- **scanme.nmap.org:** Destinazione ufficiale fornita pubblicamente dal team di sviluppo di Nmap. Questo server remoto ha lo scopo esplicito di consentire a studenti, analisti e appassionati di testare le configurazioni del software in modo del tutto legittimo e sicuro,

evitando il rischio di scansionare infrastrutture private senza esplicita autorizzazione (il che potrebbe configurarsi come un illecito o attivare sistemi di monitoraggio aziendali).

Parte 2: Mappatura Ambientale e Scansione Locale (Port Scanning)

Identificazione dell'Asset Locale:

Invocando i comandi di rete integrati nella macchina virtuale Linux di laboratorio (ip address), l'interfaccia di rete primaria denominata enp0s3 ha restituito la configurazione di seguito schematizzata:

- **Indirizzo IP della VM:** 10.0.2.15
- **Maschera di Sottorete:** 255.255.255.0 (notazione CIDR: /24)
- **Rete di Appartenenza Logica:** Sottorete 10.0.2.0/24

Risultati del Port Scanning su Host Locale (localhost):

La scansione mirata sui servizi attivi in locale ha evidenziato l'esposizione di due canali di comunicazione critici, dettagliati nella tabella sottostante:

Porta / Protocollo	Stato	Servizio Identificato	Software & Versione Rilevata	Note di Sicurezza
21/tcp	OPEN	FTP (File Transfer Protocol)	vsftpd 2.0.8 (or later)	Anonymous Login abilitato. Rischio di accesso non autorizzato ai file.
22/tcp	OPEN	SSH (Secure Shell)	OpenSSH 10.0	Canale cifrato per amministrazione e remota. Richiede credenziali robuste.

Attività di Host Discovery sulla Sottorete:

Estendendo l'ambito della scansione di ricognizione all'intero segmento di rete locale identificato (10.0.2.0/24), Nmap ha eseguito con successo la mappatura degli host attivi inviando pacchetti di probe ICMP e ARP. L'output conclusivo ha validato lo stato della rete rilevando precisamente **4 host attivi ("4 hosts up")** contemporaneamente connessi al segmento di laboratorio.

5. Bonus 2: Analisi Forense di un Attacco SQL Injection su Database MySQL tramite Wireshark

L'ispezione approfondita del file di cattura del traffico di rete denominato SQL_Lab.pcap all'interno dell'analizzatore di protocollo Wireshark ha permesso la ricostruzione temporale e metodologica completa di una violazione informatica. L'attacco analizzato è una **SQL Injection (SQLi)** condotta ai danni di un'applicazione web vulnerabile interfacciata con un database relazionale MySQL.

Analisi Tecnica della Dinamica e Timeline dell'Attacco

1. Individuazione degli Attori Coinvolti (IP di Rete):

L'analisi dei flussi TCP evidenzia una comunicazione persistente diretta verso la porta HTTP standard (80). I nodi di rete sono così identificati:

- **Indirizzo IP dell'Attaccante:** 10.0.2.4 (Sorgente dei payload malevoli)
- **Indirizzo IP della Vittima (Server Target):** 10.0.2.15 (Ospitante l'applicazione vulnerabile DVWA)

2. Fase di Tautologia ed Elusione dell'Autenticazione (Iniezione di Base):

Esaminando le prime richieste HTTP di tipo GET, si osserva l'attaccante inserire all'interno del parametro URL una stringa di input non sanificata contenente l'istruzione booleana `1=1`. Poiché l'operazione logica `OR 1=1` è matematicamente e intrinsecamente sempre vera, l'interprete SQL del database fonde questo input con la query nativa dello sviluppatore. Questo altera la logica dell'applicazione, forzando l'estrazione e la visualizzazione a schermo di tutti i record presenti nella tabella degli utenti, bypassando qualsiasi controllo di autenticazione basato su password.

3. Fase di Ricognizione delle Versioni e dell'Ambiente di Esecuzione:

Successivamente, l'attaccante ha scalato la complessità dei payload utilizzando una tecnica di iniezione basata su operatore di unione (*Union-Based SQLi*). Il pacchetto di rete mostra l'invio del payload strutturato:

1' or 1=1 union select null, version()#L'uso della funzione nativa version() accoppiata al carattere di commento # (che tronca il resto della query originale) ha costretto l'applicazione a stampare le informazioni di configurazione interna. Il database ha risposto esponendo i propri dati sensibili:

- **Versione Esatta del DBMS:** 5.7.12-0ubuntu1.1
- **Contesto Utente e Privilegi:** Account root@localhost (massimi privilegi amministrativi sul database)
- **Nome del Database Corrente:** dvwa

4. **Mappatura e Dump dell'Architettura del Database (Information Schema):**

Con l'obiettivo di localizzare tabelle contenenti dati aziendali o credenziali di accesso, l'attaccante ha effettuato una query massiccia verso la tabella di sistema globale denominata information_schema.tables. Questa operazione ha estratto l'intero schema del database, rivelando la presenza di una tabella ad alto valore denominata users.

Nota metodologica di ottimizzazione: Dall'analisi forense emerge che l'attaccante ha generato un sovraccarico di dati inutile scaricando l'elenco completo di tutte le tabelle di sistema. Se avesse raffinato la query applicando una clausola restrittiva mirata, ad esempio appendendo il filtro WHERE table_name='users', avrebbe ridotto drasticamente il rumore nei log e nel traffico di rete, forzando il database a restituire esclusivamente le informazioni strutturali relative alla specifica tabella dei target utente.

5. **Fase di Esfiltrazione Massiva dei Dati (Estrazione degli Hash):**

Una volta compresa la struttura delle colonne, l'hacker ha sferrato il payload di esfiltrazione finale:

```
union select user, password from users#
```

Il server ha risposto inviando in chiaro i record dell'applicazione. Wireshark memorizza nei pacchetti HTTP di risposta i dati esfiltrati. In particolare, è stata intercettata la riga relativa all'**ID Utente 1337**, associato al seguente hash crittografico della password:

8d3533d75ae2c3966d7e0d4fcc69216b

Sottoponendo questo hash (identificato come algoritmo standard di hashing **MD5** non salato) a un attacco basato su dizionario o a tabelle di rainbow lookup precompute (es. la piattaforma *CrackStation*), l'impronta è stata invertita istantaneamente, rivelando la password originale memorizzata in chiaro: **charlie**.

Domande di Riflessione e Approfondimento Tecnico

Valutazione dell'Impatto e del Rischio del Linguaggio SQL non protetto:

Le vulnerabilità di SQL Injection (classificate storicamente nella Top 10 dell'OWASP) rappresentano un rischio di livello *Critico* per l'integrità aziendale. Un attacco andato a buon fine mina l'intera triade CIA (Riservatezza, Integrità e Disponibilità): l'attaccante può leggere informazioni riservate bypassando i controlli, alterare o cancellare record finanziari/anagrafici, falsificare l'identità di altri utenti o amministratori ed, in determinati scenari di configurazione

errata del database (es. privilegi di scrittura file tramite INTO OUTFILE), eseguire comandi arbitrari a livello di sistema operativo sul server ospitante (Remote Code Execution - RCE).

Strategie di Prevenzione e Standard di Hardening:

Per proteggere in modo definitivo un'applicazione web dalle vulnerabilità di iniezione SQL, è necessario implementare un approccio di difesa in profondità strutturato come segue:

- **Query Parametrizzate e Prepared Statements (Contromisura Primaria):** Assicurano che l'interprete SQL tratti l'input dell'utente strettamente come un dato letterale e mai come codice eseguibile, disinnescando qualsiasi payload iniettato a prescindere dai caratteri utilizzati.
- **Validazione e Sanitizzazione Rigida degli Input:** Implementazione di controlli di tipo *Allow-list* (es. espressioni regolari) per verificare che i dati inseriti rispettino il tipo, la lunghezza e il formato atteso prima dell'elaborazione.
- **Principio del Minimo Privilegio (Principle of Least Privilege):** L'account utente utilizzato dall'applicazione web per connettersi al database deve possedere esclusivamente i permessi strettamente necessari alle sue funzioni operative (es. solo SELECT e INSERT su tabelle specifiche), inibendo categoricamente l'accesso a utenze amministrative come root o l'interrogazione degli schemi di sistema globali.
- **Dispiegamento di un Web Application Firewall (WAF):** Posizionamento di una soluzione di filtraggio perimetrale in grado di analizzare il traffico HTTP in ingresso, intercettando e bloccando preventivamente i pattern di attacco e le stringhe SQL malevole note prima che raggiungano l'applicazione.

6. Conclusioni Finali

Le attività pratiche documentate all'interno di questo report hanno permesso di analizzare sul campo l'interconnessione esistente tra la gestione dei sistemi, l'attività di ricognizione di rete e l'analisi delle minacce applicative web.

L'utilizzo avanzato di **Windows PowerShell** ha evidenziato quanto l'automazione dei processi tramite oggetti sia cruciale per il controllo operativo e per il monitoraggio continuo dei processi attivi su un host. Parallelamente, l'esplorazione sul campo delle funzionalità di **Nmap** ha ribadito l'importanza vitale della mappatura tempestiva degli asset di rete e dell'identificazione precoce dei canali di comunicazione esposti, prevenendo configurazioni insicure (come login anonimi o servizi non aggiornati).

Infine, la ricostruzione forense tramite **Wireshark** di un attacco SQL Injection ha fornito la prova

visiva e analitica di come l'assenza di controlli di sicurezza sullo sviluppo del software possa tradursi, mediante pochi passaggi sequenziali, nel compromesso totale delle credenziali degli utenti e della riservatezza aziendale. La combinazione di queste competenze costituisce la base metodologica per l'implementazione di adeguate strategie di cyber-difesa e per la conduzione professionale di attività di Ethical Hacking.

Vorrei Ringraziarla per aver contribuito alla mia educazione informatica. Grazie

LEANDRO ANCONA